Cybersecurity & NDPA Compliance Audit Report

COMPREHENSIVE SECURITY POSTURE & GOVERNANCE EVALUATION

TARGET ORGANIZATION	AUDIT FRAMEWORKS	ASSESSMENT DATE	STATUS
Nanodetails Construction & Tech	**NIST CSF 2.0 / NDPA 2023**	**October 2026**	**Final Executive Report**

EXECUTIVE SUMMARY

This audit evaluated the operational cybersecurity controls and regulatory compliance posture of **Nanodetails Construction and Technology Limited**. The organization exhibits strong foundational technical access controls, but faces elevated compliance and security exposures due to administrative gaps, unencrypted endpoint hardware, and missing statutory privacy governance under the Nigeria Data Protection Act (NDPA 2023).

2	7	1	4
CRITICAL RISKS	HIGH RISKS	MEDIUM RISK	LOW RISKS

KEY TECHNICAL & GOVERNANCE FINDINGS

Primary Strengths: Multi-Factor Authentication (MFA) is strictly enforced across corporate logins. Server data is encrypted at rest, explicit web consent is captured dynamically, and customer data processing is managed entirely in-house without third-party vendor exposures.

Primary Vulnerabilities: Workstation endpoints (laptops) lack full-disk encryption, exposing data to physical loss/theft risks. Furthermore, the company lacks a formal Incident Response Plan, an updated asset inventory, an appointed Data Protection Officer (DPO), and mandatory annual NDPC compliance filings.

> **Strategic Core Objective**
> Transition from informal, reactive safeguards to an administrative and technical security posture fully aligned with NIST CSF 2.0 standards and NDPA statutory mandates over a 180-day structured timeline.

AUDIT RISK ASSESSMENT LEDGER (14 DOMAINS)

Risk evaluation formula: **Inherent Risk = Likelihood (1–5) × Impact (1–5)**. Scale: 1–6 (Low), 8–12 (Medium), 15–16 (High), 20–25 (Critical).

#	Audit Domain / Control Focus	Client Status	Likelihood	Impact	Risk Score	Rating
1	**Asset Management Inventory**	No Inventory	4	5	**20**	CRITICAL
2	**Information Security Policy**	Undocumented	4	5	**20**	CRITICAL
3	**Multi-Factor Authentication (MFA)**	Enforced	2	2	**4**	LOW
4	**Managing Access Permissions**	Manual Admin	3	5	**15**	HIGH
5	**Data Encryption (Endpoints)**	Servers Only	5	5	**25**	CRITICAL
6	**Anti-Malware & Endpoint Defense**	Basic Tools	4	4	**16**	HIGH
7	**Incident Response Plan**	No Response Plan	5	5	**25**	CRITICAL
8	**Backup & Recovery Testing**	Never Tested	3	5	**15**	HIGH
9	**Data Protection Officer (DPO)**	Unappointed	4	4	**16**	HIGH
10	**Annual NDPC Compliance Audits**	Not Conducted	1	4	**4**	LOW
11	**Privacy Policy Transparency**	General Notice	3	5	**15**	HIGH
12	**Obtaining Explicit Consent**	Web Forms	1	2	**2**	LOW
13	**Third-Party Data Sharing**	Strictly Internal	1	2	**2**	LOW
14	**Right to Erasure Process**	Web Delete Button	3	4	**12**	MEDIUM

RISK SCORE ANALYSIS

> **Audit Observation**
> The highest risk concentration stems from unencrypted mobile endpoints (Item 5) and the complete absence of an Incident Response Plan (Item 7). Resolving these two items removes over 30% of total identified inherent operational risk.

REMEDIATION ROADMAP & ACTION PLAN

Phase 1: Immediate Critical Fixes

Days 0 – 30

- **Full-Disk Encryption (Item 5):** Deploy BitLocker (Windows) and FileVault (macOS) across all employee laptops and workstation endpoints.
- **Incident Response Playbook (Item 7):** Draft an active Incident Response Plan outlining breach containment steps and 72-hour NDPC notification triggers.
- **Asset Registry Baseline (Item 1):** Establish a centralized, living inventory of all hardware assets, software licenses, and cloud instances.

Phase 2: High-Priority Controls & Operations

Days 30 – 90

- **Information Security & BYOD Policy (Item 2):** Formalize and distribute written security rules, password complexity standards, and personal device (BYOD) protocols.
- **EDR Defense Upgrade (Item 6):** Upgrade legacy anti-malware to Endpoint Detection and Response (EDR) for automated threat telemetry.
- **Offboarding Checklist (Item 4):** Implement standardized HR/IT offboarding workflows to revoke access instantly upon employee role changes or exits.
- **Backup Restoration Drills (Item 8):** Conduct quarterly backup restoration tests to verify database recovery integrity.
- **Erasure Alignment (Item 14):** Verify web deletion requests trigger complete backend database and backup log purges.

Phase 3: Legal & Statutory Privacy Governance

Days 90 – 180

- **Data Protection Officer Appointment (Item 9):** Officially designate internal or outsourced certified DPO representation under Section 32 of NDPA 2023.
- **Privacy Notice Overhaul (Item 11):** Update web privacy policies to explicitly detail processing legal bases, storage limits, and user rights.
- **NDPC Audit Filing (Item 10):** Execute the formal annual compliance audit and submit statutory documentation to the NDPC.

IMPLEMENTATION OVERSIGHT

Progress should be reviewed on a bi-weekly basis by executive management. Completing Phase 1 immediately eliminates critical regulatory liabilities, while Phases 2 and 3 ensure sustainable, long-term compliance and operational resilience.